

PART 7 OF 18

AI Authorization Architecture

RBAC vs ABAC vs PBAC, Policy-as-Code, Dynamic Authorization, Cedar, OPA/Rego, OpenFGA, Risk-Adaptive Access Control for Autonomous Agents

ENTERPRISE AI CONTROL ARCHITECTURE

Implementation Guide for Production AI Systems • 2026

7.1 Authorization Challenges for Autonomous Agents

Authorization for autonomous AI agents is fundamentally different from authorization for human users or traditional software services. Human authorization is relatively static—a user’s role changes infrequently and their access needs are well-characterized. Agent authorization is dynamic—the same agent type may need entirely different permissions depending on the specific task, the user it is acting for, the current risk context, and the phase of a multi-step workflow.

Authorization Principle for Agents: *Authorization decisions must be goal-aware, context-sensitive, risk-adaptive, and reversibility-conscious. A permission granted for reading data should not automatically extend to writing data, even if both are within a traditional role's scope. Each action requires independent evaluation against current context.*

7.2 Authorization Model Comparison

Model	Decision Based On	AI Agent Fit	Key Limitation
RBAC	User role membership	Poor	Roles too coarse; cannot express task-specific permissions
ABAC	Attributes of subject, resource, environment	Moderate	Does not capture agent goal state or action intent
PBAC (Policy-Based)	Explicit policy rules over context	Good	Policy authoring complexity; performance at scale
ReBAC (Relationship-Based)	Entity relationship graph (Zanzibar)	Moderate	Relationships don't capture temporal or goal context
Capability-Based	Possession of unforgeable capability token	Good	Token management complexity; revocation challenges
Risk-Adaptive	Real-time risk score drives access level	Excellent	Risk model quality determines security efficacy
Goal-Aware (emerging)	Agent goal + context + risk	Excellent	No production frameworks exist yet (2026)

7.3 Cedar: Policy Language for AI Agent Authorization

AWS Cedar, open-sourced in 2023, is the most suitable general-purpose policy language for AI agent authorization. Cedar is designed for: fast evaluation (policies evaluate in sub-millisecond time), strong typing (prevents policy authoring errors), formal verification (policy correctness can be proven), and human readability. Cedar is used by Amazon Verified Permissions and Amazon Bedrock AgentCore.

7.3.1 Cedar Policy Examples for AI Agents

```

■ // Allow finance analyst agent to read financial reports for tasks delegated by finance team
permit( principal in AgentType::"finance-analyst", action == Action::"read", resource in
DataScope::"financial-reports" ) when { principal.task_delegated_by in Group::"finance-team"
&& principal.risk_score < 50 && resource.classification <= "CONFIDENTIAL" &&
context.time_of_day.hour >= 6 && context.time_of_day.hour <= 20 };

```

```

■ // Forbid any agent from deleting records with external effects forbid( principal is
AgentInstance, action in [Action::"delete", Action::"purge"], resource ) unless {
principal.human_approval_received == true && principal.approval_for_resource == resource.id
&& context.approval_timestamp > now() - duration("15m") };

```

7.4 OPA/Rego for Complex AI Agent Policies

Open Policy Agent (OPA) with the Rego policy language provides more expressive power than Cedar for complex, context-rich authorization decisions. OPA is particularly suitable for behavioral policy evaluation where the authorization decision depends on patterns across the agent's action history.

7.4.1 OPA Integration Architecture

- **Sidecar Pattern:** OPA runs as a sidecar container in the agent pod; policy decisions made via local HTTP call (< 5ms)
- **Bundle Distribution:** Policy bundles distributed via OPA Bundle API; agents always run latest approved policies
- **External Data:** OPA integrates with agent context store (action history, risk scores) via External Data API
- **Decision Logging:** All OPA decisions logged to central decision log with full input/output; enables policy auditing
- **Partial Evaluation:** Pre-compile policies for known agent types to reduce per-request evaluation overhead

7.5 OpenFGA / Zanzibar for Relationship-Based Authorization

OpenFGA (Open Fine-Grained Authorization), based on Google's Zanzibar system, provides relationship-based access control (ReBAC) with highly scalable, low-latency authorization. For AI agents, OpenFGA is particularly valuable for authorization decisions that depend on organizational relationships: 'can this agent access resources owned by the user who delegated this task?'

7.5.1 ReBAC for Agent Delegation

■ OpenFGA Tuple Example for Agent Delegation: # Alice owns the finance report user:alice | owner | document:finance-report-q2 # Alice delegates to finance-analyst agent agent:finance-analyst-sess-a7f2b1 | delegate_of | user:alice # ReBAC check: can agent read document alice owns? # Resolution: agent -> delegate_of -> alice -> owner -> document -> can read check(agent:finance-analyst-sess-a7f2b1, reader, document:finance-report-q2) = true

7.6 Risk-Adaptive Authorization

Risk-adaptive authorization (RAA) adjusts the authorization threshold dynamically based on real-time risk signals. For AI agents, risk signals include: current behavioral anomaly score, cumulative session risk, environmental threat indicators, time-of-day factors, and sensitivity of the requested resource.

Risk Level	Score Range	Access Controls	Human Oversight
Very Low (Routine)	0-20	Automatic approval; minimal logging	Random sampling audit
Low (Normal)	21-40	Automatic approval; standard logging	Exception-based review
Medium (Elevated)	41-60	Automatic approval; enhanced logging; behavioral alert	Alert to SOC; no blocking
High (Concerning)	61-80	Require additional attestation; gate on sensitive actions	Human review required for flagged actions
Very High (Suspicious)	81-95	Block all non-read actions; human must authorize each write	Active monitoring; SOC escalation
Critical (Quarantine)	96-100	Block all actions; agent quarantined	Immediate incident response